David Londoño

+57 317 2939347 | dlondon.dev@gmail.com | linkedin.com/in/davidldv | github.com/davidldv | davidlondon.dev

Software Engineer, Application Security. Full-Stack Engineer at KitchenSync on a restaurant back-office platform that handles payroll and payments data. Outside work I write the tools that attack systems like it: an IDOR/BOLA scanner scored against **16** seeded bugs, and labs covering JWT internals and LLM/MCP attack surfaces. English C1, Spanish native, German B1. Remote (LATAM/EU/US) or open to relocation.

Work Experience

KitchenSync **Oct 2026 – Present**
Full-Stack Engineer (Contract) *Remote*

- Build **Kit**, a restaurant back-office platform (accounting, payroll, accounts payable), across **React**, **Node.js** and **PostgreSQL**.
- Unifying point-of-sale providers behind one **validated adapter layer**, so third-party data is checked at a single boundary, and moving background syncs onto a durable, **idempotent job queue**.
- Ship through small, **CI-gated** pull requests with safe schema migrations. Use AI coding agents daily, scoping their work and reviewing what they produce.

Tambora **Jul 2025 – Sep 2025**
Frontend Developer (Contract) *Remote*

- Migrated business-critical legacy modules from jQuery to **React** and cut bundle size by **40%** on the rebuilt surfaces, dropping the ad-hoc DOM string injection along with it.
- Replaced manual SSH deploys with **Azure CI/CD** pipelines and took deployment time from over **two hours to under fifteen minutes**. The automated test gates are where SAST and dependency scanning hook in.

Security Engineering Projects

authzscan | *Source Code* | *Overview* **TypeScript** | **ts-morph** | **SARIF**
Autonomous IDOR/BOLA review for Next.js App Router codebases, driven by Claude agents.

- A deterministic **ts-morph** inventory of route handlers and Server Actions, a trace agent that follows each client-controlled identifier to the query it reaches, and a verify agent that knocks down false positives. Outputs **SARIF**, Markdown or JSON with CI exit codes.
- The accuracy is a number, not a feeling: **16** seeded IDOR/BOLA bugs plus **6** correctly authorized twins that exist to catch false positives, gated on recall and precision. An oracle runner checks the harness scores right no matter how good the model is.

JWT Security Lab & **jwt-scan** | *Source Code* **TypeScript** | **Node.js** | **Docker**
Offense-and-defense JWT lab, shipped as an npm CLI scanner.

- Wrote JWT signing and verification from scratch in TypeScript to reproduce five production flaws: **alg=none**, **HS256/RS256 key confusion**, weak-secret brute force, **kid** path traversal, and missing **iss/aud/exp** checks. The checks ship as **jwt-scan**, an npm CLI with CI-friendly exit codes.

LLM/RAG Security Lab | *Source Code* **Python** | **FastAPI** | **MCP** | **Docker**
Five OWASP LLM Top 10 attacks as a pytest suite against a vulnerable/hardened FastAPI pair.

- Reproduced and fixed five LLM-specific classes on one RAG surface: **cross-tenant retrieval** (confused deputy), **indirect prompt injection** through retrieved documents, vector-store **poisoning** via forged ingest metadata, **excessive agency** over a live **MCP** tool server, and stored **XSS** straight out of the model.

Materiales La Bodega | *Live Site* **Next.js** | **PostgreSQL** | **Mercado Pago**
Solo-built e-commerce platform, live in production for a hardware retailer.

- The only engineer on a live storefront moving about **$1.5M COP/day**. Built its auth, session security and **RBAC**, and hardened it against the **OWASP Top 10**.

Certifications & Security Training

Completed: Google Professional Cybersecurity Certificate, PortSwigger Web Security Academy (all free labs).

In progress: Burp Suite Certified Practitioner (BSCP), CompTIA Security+. **Practice**: HackTheBox (@davidldv), TryHackMe (dlondon.dev), CTF challenges.

Technical Skills

Security: OWASP Top 10 (Web + LLM), IDOR/BOLA & broken access control, penetration testing, OAuth 2.0 / OIDC, JWT, RBAC, CSRF, XSS and SQLi defense, session security, threat modeling (STRIDE), secure code review, prompt-injection defense.

Tooling: Burp Suite, Semgrep, Trivy, nmap, Wireshark, SARIF / GitHub code scanning, Docker, Linux, Git.

Languages: TypeScript, JavaScript, Python, C, SQL, Bash.

Frameworks & Data: Next.js, React, Node.js, FastAPI, Prisma, PostgreSQL, MongoDB, REST, WebSockets, Jest, Zod.

Cloud & DevOps: AWS, Azure, CI/CD (Azure Pipelines, GitHub Actions), containerization.

Education

Universidad Tecnológica de Pereira, Pereira, Colombia. Systems & Computing Engineering, in progress (Feb 2022 to present).

EliteStack Bootcamp, Pereira, Colombia. Full-Stack Development (Jun 2024 to Jul 2024).